AWS SAA（SAA-C03）　分野1 セキュアなアーキテクチャの設計　#01

IAMとポリシー

だれが、何に、どの条件でアクセスできるか。許可はどう決まるか

各ページの下に、根拠にした AWS の公式ドキュメント（日本語版の IAM ユーザーガイドと SAA-C03 試験ガイド）を書いた（青い文字を押すと開く）。「」の中はドキュメントの原文どおり。会社名や場面は Claude が作った例

全体像 試験ガイド タスク 1.1「AWS リソースへのセキュアなアクセスを設計する」

1 だれがアクセスするか（ID）
ルートユーザー・IAM ユーザー・グループ・ロール。人もアプリも、できるだけ一時的な認証情報で

2 ポリシーの書き方
ID に付けるか、リソースに付けるか。Effect・Action・Resource・Principal・Condition

3 許可の決まり方
最初は全部拒否。Allow で開き、明示的な Deny がいちばん強い。境界は上限だけ

4 最小権限と点検
必要な分だけ。Access Analyzer・認証情報レポート・最終アクセス情報で見直す

タスク 1.1 の知識・スキル（要約）	このPDF
AWS のサービスへのアクセス制御とアクセス管理	第1・2章
ルートユーザーの保護、MFA	第1章
ユーザー・グループ・ロール・ポリシーの柔軟な認可モデル	第1・2章
最小権限の原則	第3章
クロスアカウントアクセスの戦略	第3章
Organizations・SCP・フェデレーション・Identity Center	#02 で

> **本番の問題は「場面」で出る。**「EC2 のアプリに S3 を読ませたい」「別アカウントに見せたい」のような要件に、いちばん安全で手間の少ないしくみを選ぶ。

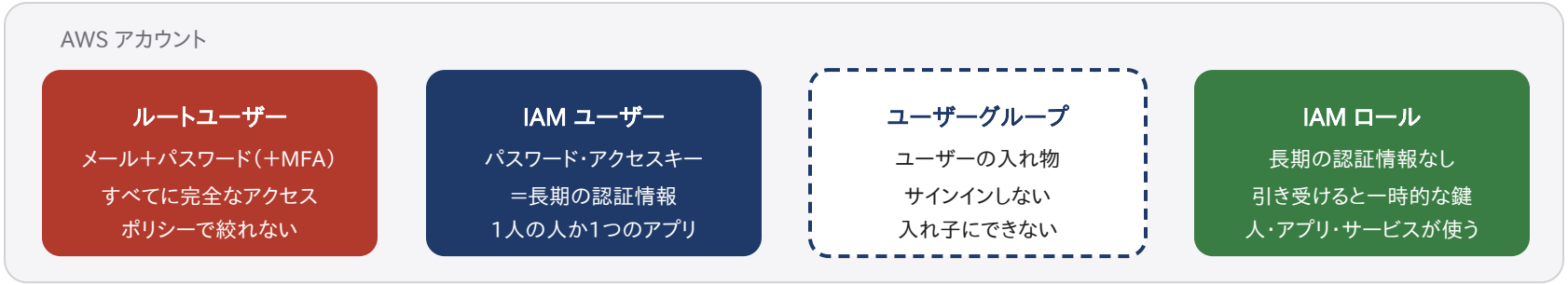
出典：AWS「コンテンツ分野 1: セキュアなアーキテクチャの設計」タスク 1.1 の知識の一覧

第1章

だれがアクセスするか（ID）

人には人の ID、アプリやサービスにはロール。長く使える鍵はなるべく持たせない。

4つの ID：だれの・どんな鍵か



ID	AWS のおすすめの使い方	ひっかけ
ルートユーザー	ルートでしかできない作業のときだけ。MFA で守る	ID ベースのポリシーも境界も付けられない
IAM ユーザー	フェデレーションが使えない場合だけ（ロール非対応のツール・緊急用など）	アクセスキーは1人2つまで
グループ	同じ権限の人をまとめ、出入りだけで管理	Principal に書けない／全員が入る既定のグループはない
ロール	EC2・Lambda のアプリ、別アカウント、外部 IdP の人	「ユーザーを作ってキーを配る」より、ほぼいつもロール

出典：IAM ロール（「ロールには標準の長期認証情報 (パスワードやアクセスキーなど) も関連付けられません。」）／IAM ユーザーグループ／アクセスキーを管理します

ルートユーザー：使うのは「ルートでしかできない作業」だけ

ルートでしかできない作業（ドキュメントの一覧から抜粋）

分類	作業
アカウント	単独のアカウント（Organizations に入っていない）の設定変更・閉鎖・再開
IAM	ただ1人の IAM 管理者が自分の権限を消してしまったときの復旧
S3	MFA に対応するようバケットを設定する（MFA 削除）／すべてのプリンシパルを拒否してしまったバケットポリシーの編集・削除
EC2	リザーブドインスタンスマーケットプレイスへの出品者の登録
請求	請求情報とコスト管理コンソールへの IAM アクセスをオンにする

ルートユーザーとポリシー

ID ベースのポリシーを付けられない。アクセス許可の境界も設定できない。

ただし Organizations のメンバーアカウントなら、ルートユーザーも **SCP の制限を受ける**（#02）。

守り方

・日常の作業には使わない（管理者は IAM Identity Center などで用意）

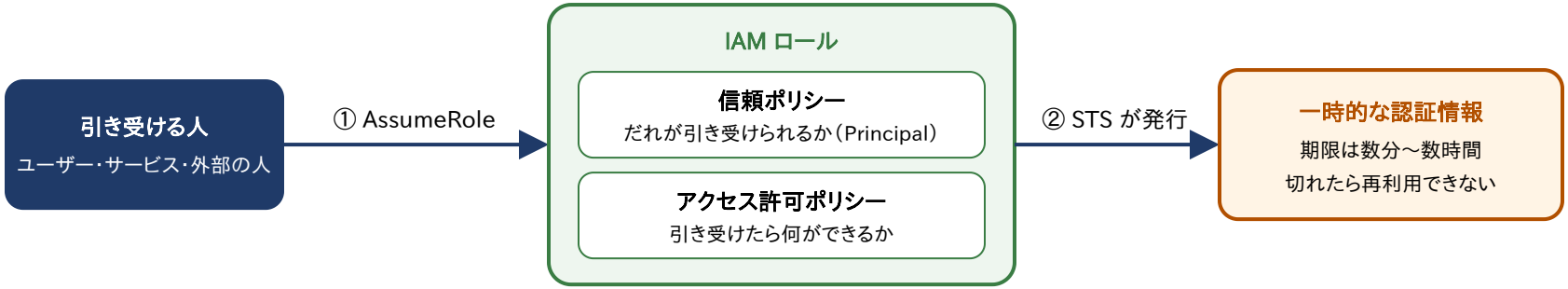
・MFA を付ける（ルートと IAM ユーザーは1人あたり最大8台の MFA 機器を登録できる）

・ルートのアクセスキーは作らない

ひっかけ：「IAM ユーザーを作る」「EC2 を起動する」「CloudTrail の証跡を作る」はルートでなくてよい（権限のある IAM の ID で行う）。

出典：AWS アカウントのルートユーザー（ルートユーザー認証情報が必要なタスク）／ポリシーとアクセス許可（ポリシーとルートユーザー）／AWSIAM の多要素認証

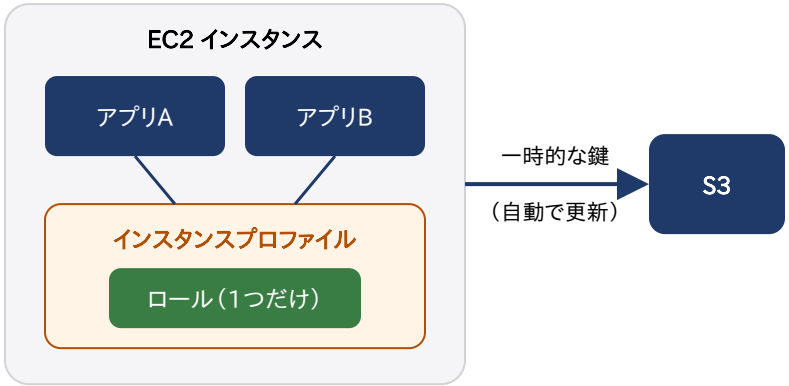
ロールのしくみ：2枚のポリシーと一時的な鍵



STS の API	だれが使う	覚え方
AssumeRole	IAM ユーザーやロール（同じ・別のアカウント）	基本形。最大セッション時間まで（最大12時間）
AssumeRoleWithSAML	SAML 2.0 の IdP（社内の AD など）で認証した人	#02 フェデレーション
AssumeRoleWithWebIdentity	OIDC の IdP の JWT を持つワークロード	#02
ロールの連鎖	ロールの認証情報で、さらに別のロールを引き受ける	最長1時間。超える値は失敗

出典：IAM ロール（ロールに関する用語と概念：信頼ポリシー・委任・ロールの連鎖「最大 43200 秒 (12 時間)」）／IAM の一時的な認証情報（「有効期限は数分から数時間に設定できます。」）

EC2 にロールを渡す：インスタンスプロファイル



決まり	中身
プロファイルに入るロール	**1つだけ（上限は上げられない）**
インスタンスに同時に付くロール	**1つだけ。アプリはみな同じ権限**
コンソールで EC2 用のロールを作ると	**同じ名前のプロファイルが自動でできる**
起動中のインスタンス	**あとからロールを付けられる**
アプリごとに権限を分けたい	**ECS ならタスクごとにロールを付けられる**

> **アクセスキーを置かない理由：**ロールの認証情報は一時的で自動で更新されるので、配ったり入れ替えたりする手間も、漏れたときの長期のリスクもない。

ロールをサービスに付ける人には `iam:PassRole` の許可が要る（第3章）。

出典：インスタンスプロファイルを使用する（「インスタンスプロファイルに含めることができる IAM ロールは 1 つのみです。」）／EC2 インスタンスで実行されるアプリケーションに IAM ロールを使用（「同時に Amazon EC2 インスタンスに割り当てることができるのは 1 つのロールだけです。」）

長期の鍵と一時的な鍵

	アクセスキー（長期）	STS の一時的な認証情報
持ち主	IAM ユーザー（とルート）	ロールを引き受けたセッションなど
期限	消すまで使える	数分〜数時間
保存	ユーザーに結びついて残る	保存されず、そのつど作られる
数	1人2つまで	—
入れ替え	自分で（新を作る→旧を消す）	期限で自然に切れる
シークレット	作ったときしか見られない	—

IAM のベストプラクティス（見出しから抜粋）

- 人間のユーザーは ID プロバイダーとのフェデレーションで一時的な認証情報を使う
- ワークロードは IAM ロールの一時的な認証情報を使う
- MFA を必須にする
- 長期の認証情報が要る場合は、アクセスキーを必要なときに更新する
- ルートユーザーの認証情報を守る
- 最小権限を適用する
- 未使用のユーザー・ロール・権限・認証情報を定期的に消す

> **選択肢の見分け方：**「アクセスキーをコード・設定ファイル・AMI に入れる」が出たら、ほぼ誤り。ロールに置き換えられないかを考える。

出典：IAM の一時的な認証情報／IAM ユーザーのアクセスキーを管理します（「アクセスキーはユーザーごとに最大 2 つまで持つことができます。」）／IAM でのセキュリティのベストプラクティス

第2章

ポリシーの書き方

どこに付けるか（ID か、リソースか）と、許可を与えるか（上限だけか）で
種類を分ける。

ポリシーの種類：許可を「与える」ものと「上限を決める」もの

種類	付ける先	許可を与えるか	ポイント
ID ベースのポリシー	ユーザー・グループ・ロール	与える	管理ポリシー（AWS 管理・カスタマー管理）とインライン。Principal は書かない
リソースベースのポリシー	S3 バケット・SQS キュー・KMS キー・ロール（信頼ポリシー）など	与える	インラインだけ。Principal に相手を書く。別アカウントも指定できる
VPC エンドポイントポリシー	VPC エンドポイント	追加の境界	付けないと、フルアクセスを許すデフォルトのポリシーが付く
アクセス許可の境界	ユーザー・ロール	与えない	ID ベースのポリシーの上限。リソースベースのポリシーの許可は絞らない
SCP（#02）	組織・OU・アカウント	与えない	アカウントの中のユーザーとロールの上限（メンバーのルートも）
RCP（#02）	組織・OU・アカウント	与えない	アカウントの中のリソースの上限
ACL	S3・VPC など	与える	JSON でない唯一の種類。別アカウントにだけ使える
セッションポリシー	ロールを引き受けるときに渡す	与えない	セッションの権限＝ID ベースとの共通部分

「与えない」組は、どれも Allow を書いても権限は増えない。実際の権限は、与える側のポリシーの Allow を、上限の側で削ったもの。

出典：AWS Identity and Access Management でのポリシーとアクセス許可（ポリシータイプ。「SCP は許可を付与するものではありません。」「ACL では、同じアカウント内のエンティティにアクセス許可を付与することはできません。」）

ID ベースのポリシー：3つの持ち方

	AWS 管理	カスタマー管理	インライン
作る人	AWS	自分	自分
中身の変更	**できない**	**できる**	**できる**
付けられる数	多数	多数	1つの ID だけ
ID を消すと	残る	残る	**いっしょに消える**
ARN	それぞれの ARN を持つ（独立したポリシー）		なし

AWS 管理ポリシーの例：`arn:aws:iam::aws:policy/IAMReadOnlyAccess`（アカウント ID の位置が `aws`）

こんなとき	選ぶもの
まず手早く始めたい（よくある職務の権限）	**AWS 管理**
必要な分だけに絞った権限を、複数のロールで使い回す	**カスタマー管理**
特定の1つの ID だけに付け、流用させない	**インライン**

> **AWS のおすすめの流れ：**AWS 管理ポリシーで始め、使われた操作を見ながら、最小権限のカスタマー管理ポリシーへ移る。

AWS 管理ポリシーは AWS がときどき更新し、付けている全員にすぐ効く。

出典：管理ポリシーとインラインポリシー（表と「AWS 管理ポリシーで定義されているアクセス許可は変更できません。」）／ベストプラクティス（AWS 管理ポリシーの使用を開始し、最小特権のアクセス許可に移行する）

ポリシーの JSON を読む

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadOwnFolder",
      "Effect": "Allow",
      "Action": ["s3:GetObject", "s3:PutObject"],
      "Resource": "arn:aws:s3:::example-bucket/home/${aws:username}/*",
      "Condition": {
        "Bool": { "aws:SecureTransport": "true" }
      }
    }
  ]
}
```

Claude が作った例。ユーザーが自分のフォルダだけを、HTTPS のときだけ読み書きできる。

要素	意味
Version	`2012-10-17` を使う（変数もこの版から）
Statement	1つ以上。複数あれば OR でまとめて評価
Effect	`Allow` か `Deny`
Action	操作。`NotAction` は「これ以外すべて」（拒否ではない）
Resource	対象の ARN。ID ベースでは必須
Principal	相手。リソースベースで使う。ID ベースには書けない
Condition	効く条件。true のときだけそのステートメントが効く

ARN の形：`arn:aws:サービス:リージョン:アカウント:リソース`。IAM はリージョンが空、S3 バケットはリージョンもアカウントも空。

出典：ポリシーとアクセス許可（JSON ポリシードキュメント構造）／NotAction／ポリシー変数／ARN

Condition でよく使う条件キー

条件キー	比べるもの	本番での使いどころ
aws:SourceIp	リクエスト元の IP アドレス（パブリック IP だけ）	社内の IP からだけ許可。**VPC エンドポイント経由のリクエストには含まれない**
aws:SourceVpce	リクエストが通った VPC エンドポイントの ID	S3 バケットを「この VPC エンドポイント経由だけ」にする
aws:RequestedRegion	呼び出されたリージョン	使えるリージョンを限る
aws:MultiFactorAuthPresent	一時的な認証情報を MFA で確かめたか	大事な操作は MFA のときだけ。アクセスキーで署名したリクエストには含まれない
aws:SecureTransport	TLS で送られたか（true／false）	false を Deny して HTTPS を強制
aws:PrincipalOrgID	プリンシパルが属する組織の ID	バケットを自分の組織のアカウントだけに開く（#02）
sts:ExternalId	ロールを引き受けるときに渡された外部 ID	第三者に委任するロールの信頼ポリシー（第3章）

キーの名前は大文字・小文字を区別しない（aws:SourceIP と AWS:SourceIp は同じ）。aws: で始まるのがどのサービスでも使えるグローバル条件キー。

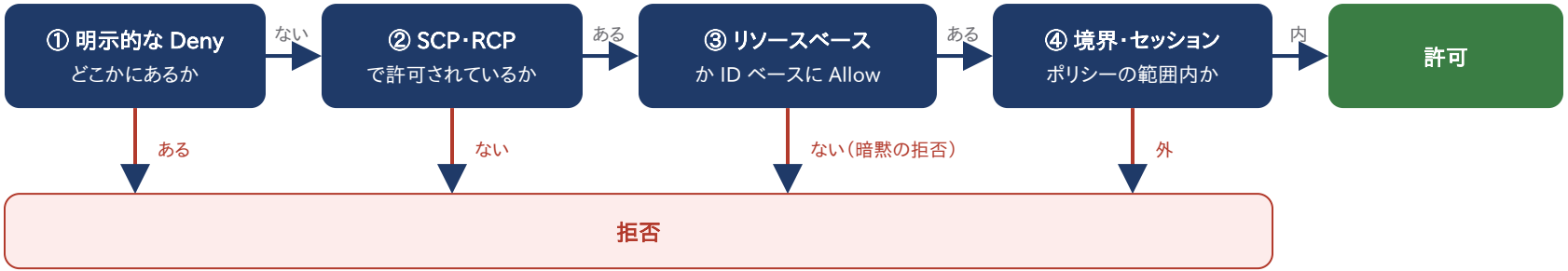
出典：AWS グローバル条件コンテキストキー（各キーの説明と「可用性」）／IAM JSON ポリシー要素Condition

第3章

許可の決まり方と絞り込み

最初はすべて拒否。Allow で開き、明示的な Deny はどこにあっても勝つ。

1つのアカウントの中での判定の流れ



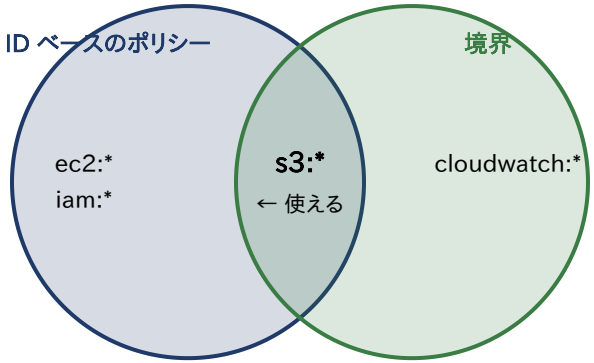
ドキュメントの評価の流れを、本番で使う形に簡単にした図。細かい例外（同じアカウントでリソースベースのポリシーが直接許可する場合など）は省いた

暗黙的な拒否：ルートユーザー以外のリクエストは、最初はすべて拒否されている。Allow があって初めて開く。

明示的な拒否：どの種類のポリシーにあっても、ほかの Allow より強い。ポリシーの順番や範囲の広さは関係ない。

出典：エンフォースメントコードロジックがリクエストを評価してアクセスを許可または拒否する方法（「明示的な拒否は明示的な許可をオーバーライドします。」）

アクセス許可の境界：共通部分だけが使える



Claude が作った例

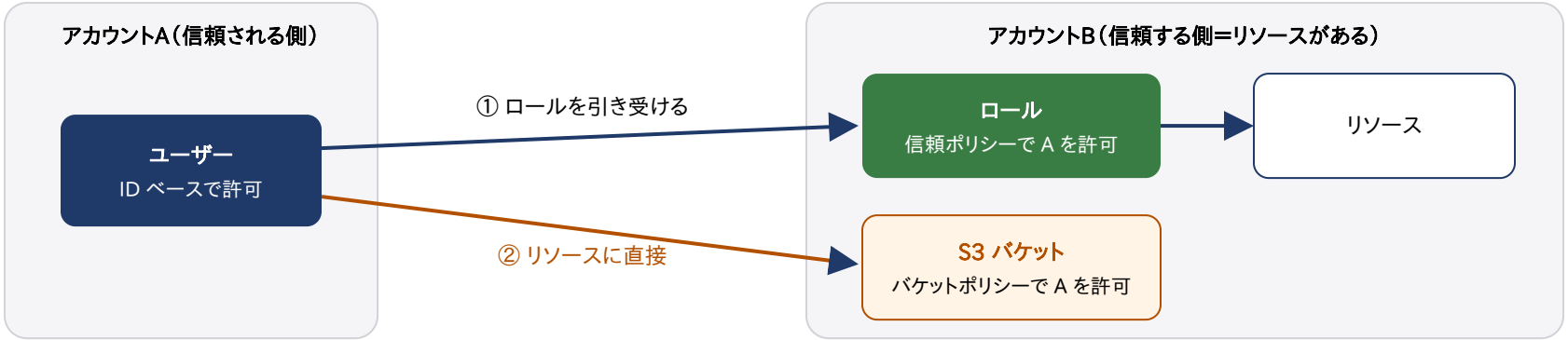
ポイント	中身
付ける先	**ユーザーかロール（グループには付かない）**
何で設定するか	**管理ポリシー（AWS 管理かカスタマー管理）**
権限を与えるか	**与えない（上限だけ）**
リソースベースのポリシーの許可	**境界では絞られない**

> **代表的な使い方＝管理の委任：**開発者に「ロールを作ってよい。ただし、この境界を付けたものだけ」と任せる。開発者が強いポリシーを付けても、境界を超えられない。

似たもの：SCP はアカウント全体の上限（#02）、セッションポリシーはそのセッションだけの上限。

出典：IAM エンティティのアクセス許可境界（「アイデンティティベースのポリシーとそのアクセス許可の境界の両方で許可されているアクションのみを実行できます。」）／ベストプラクティス（アクセス許可の境界を使用して、アカウント内のアクセス許可の管理を委任する）

別のアカウントのリソースを使わせる2つの方法



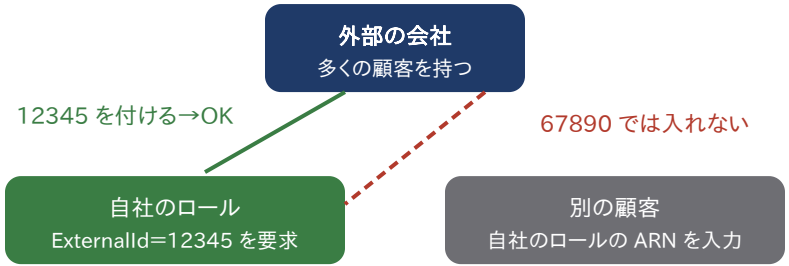
方法	しくみ	ちがい
① ロール	B にロールを作り、信頼ポリシーで A を許可。A 側では `sts:AssumeRole` を許可	引き受けている間は、元の権限は使えない（ロールの権限になる）
② リソースベース	S3・SNS・SQS などのリソースのポリシーで A を許可。A 側では ID ベースのポリシーでそのリソースを許可	元の権限のまま使える。対応しているサービスだけ

どちらも「両側の許可」が要る。リソース側のポリシーに相手を書くだけでは信頼関係の半分。

出典：クロスアカウントポリシーの評価論理／ポリシーとアクセス許可（「信頼関係は半分しか確立されない」）／IAM ロール（委任・クロスアカウントアクセスのロール）

委任の落とし穴をふさぐ：外部 ID と PassRole

外部 ID（混乱した代理問題の対策）



外部の会社が顧客ごとに一意の値を決め、顧客は信頼ポリシーの条件 `sts:ExternalId` でその値を要求する。値は Claude が作った例。

iam:PassRole

場面	要る許可
EC2 を起動して既存のロールを付ける	**`ec2:RunInstances` ＋ そのロールへの `iam:PassRole`**
Lambda 関数に実行ロールを設定する	**そのロールへの `iam:PassRole`**
自分でロールを引き受ける	**`sts:AssumeRole`（PassRole とは別）**

> **なぜ要るか：**自分の権限は弱くても、強いロールをサービスに付ければ、そのサービス経由で強い操作ができてしまう。渡してよいロールを PassRole で限る。

PassRole で渡せるのは同じアカウントのサービスだけ。

出典：混乱する代理問題（「ロールの信頼ポリシーに `ExternalId` の条件の確認を含めることを必須とする」）／AWS サービスにロールを渡すアクセス許可をユーザーに付与する

最小権限と点検の道具

道具	分かること・できること	こう聞かれたら
IAM Access Analyzer（外部アクセス）	リソースベースのポリシーを分析し、外部（別アカウント・組織の外）と共有されている S3 バケットや IAM ロールを見つける	「意図せず公開・共有されたリソースを探す」
IAM Access Analyzer（未使用のアクセス）	使われていない権限を見つける	「余分な権限を洗い出す」
IAM Access Analyzer（ポリシーの生成・検証）	CloudTrail のアクセスの記録から、実際に使った操作だけのポリシーを作る／ポリシーを文法とベストプラクティスで確かめる	「実際の利用に合わせて最小権限のポリシーを作る」
最終アクセス情報	ユーザー・グループ・ロール・ポリシーが、各サービスに最後にアクセスした日時（アクセスアドバイザー）	「使っていないサービスの権限を外す」
認証情報レポート	全ユーザーのパスワード・アクセスキー・MFA 機器などの状態の一覧	「MFA なしのユーザー、古いアクセスキーを一覧に」

最小権限：タスクに必要な権限だけを、決まったリソースと条件で与える。広めに始めて、使われ方を見て絞るのが AWS の進め方。

出典：IAM Access Analyzer の使用／認証情報レポート／ベストプラクティス（最小特権アクセス許可を適用する・未使用の…を定期的に確認して削除する）

まとめ

ID
ルートは特別な作業だけ。アプリやサービスにはロール。グループは入れ子にできない

ポリシー
ID ベース（管理・インライン）とリソースベース（Principal を書く）。境界・SCP・セッションは上限だけ

判定
最初は全部拒否。Allow で開き、明示的な Deny が最強。境界とは共通部分

委任と点検
別アカウントは両側の許可。外部 ID・PassRole。Access Analyzer と認証情報レポート

こんな要件なら	答え
EC2 のアプリに S3 を読ませる	**ロール（インスタンスプロファイル）**
開発者にロール作成を任せ、上限をかける	**アクセス許可の境界**
外部の会社に自社のロールを使わせる	**信頼ポリシー＋外部 ID**
HTTPS 以外を断る	**aws:SecureTransport が false を Deny**
外部に共有されたリソースを探す	**IAM Access Analyzer**
MFA なしのユーザーの一覧	**認証情報レポート**

次の #02 では、アカウントをまとめる Organizations・SCP と、社員の ID をつなぐ IAM Identity Center・フェデレーションを扱う。

出典：このPDFの各ページの資料